

Informe Técnico de Seguridad Aplicada en Plataforma Web

Título: Análisis de Seguridad y Explotación de Vulnerabilidades en una Aplicación Web de Comercio Electrónico

Resumen Ejecutivo

Se ha llevado a cabo un proceso de análisis de seguridad ofensiva sobre una aplicación web de e-commerce con funcionalidades completas de registro, autenticación, búsqueda de productos y gestión de cuentas. El objetivo fue identificar vulnerabilidades críticas en los puntos de entrada comunes de usuario, simular escenarios de explotación realistas y proporcionar medidas de mitigación orientadas a la protección de datos y la prevención de abusos en el flujo transaccional de la plataforma.

Metodología

La auditoría se desarrolló mediante pruebas manuales y asistidas, apoyadas en herramientas como OWASP ZAP y Burp Suite. Se inspeccionó el tráfico HTTP, se interceptaron solicitudes en tiempo real, y se introdujeron cargas maliciosas en formularios y parámetros de entrada. La evaluación se centró en vulnerabilidades que afectan a la confidencialidad, integridad y disponibilidad de la aplicación, alineadas con el marco OWASP.

Vulnerabilidad 1: Inyección SQL en campo de búsqueda

Descripción técnica

Se detectó que el formulario de búsqueda de productos no valida ni filtra correctamente las entradas del usuario antes de construir consultas SQL. Esto permite inyectar comandos arbitrarios que interactúan directamente con la base de datos subyacente.

Evidencia

Al ingresar la carga `' OR 1=1 --` en el campo de búsqueda, el sistema devuelve todos los productos existentes, lo que indica una interpolación directa en la consulta. La ausencia de errores sugiere que no se emplean sentencias preparadas ni mecanismos de sanitización.

Impacto

Un atacante podría escalar esta vulnerabilidad para extraer datos sensibles de otras tablas, modificar registros, evadir autenticación, o realizar un ataque de denegación mediante alteración de las condiciones de consulta.

Recomendación

Implementar sentencias parametrizadas en todos los accesos a bases de datos. Utilizar ORM que impidan la concatenación directa. Validar las entradas mediante listas blancas y aplicar técnicas de escape de caracteres SQL.

Vulnerabilidad 2: Cross-Site Scripting reflejado en formularios

Descripción técnica

Se identificó un punto de entrada vulnerable al ataque de inyección de scripts en formularios de búsqueda y contacto. Las entradas del usuario son devueltas en la respuesta sin proceso de codificación adecuado, permitiendo la ejecución arbitraria de código JavaScript en el navegador del cliente.

Evidencia

Al introducir `<script>alert(document.cookie)</script>` como valor en un formulario, el script se ejecuta en el navegador, evidenciando una inyección XSS reflejada. Esta vulnerabilidad es explotable sin autenticación previa.

Impacto

Un atacante puede robar sesiones, redirigir a sitios maliciosos, modificar dinámicamente el contenido del DOM o capturar interacciones del usuario. El riesgo es crítico si el usuario objetivo está autenticado.

Recomendación

Escapar correctamente los caracteres especiales en todas las salidas HTML. Utilizar funciones de codificación contextuales según el tipo de respuesta (HTML, JavaScript, URL). Implementar políticas de seguridad de contenido (CSP) restrictivas para prevenir la ejecución de código no autorizado.

Vulnerabilidad 3: Exposición de información sensible en respuestas

Descripción técnica

Durante la inspección de tráfico entre cliente y servidor, se observaron tokens de sesión, direcciones de correo, y estructuras internas expuestas dentro de las respuestas JSON y del código JavaScript enviado al navegador.

Evidencia

El análisis de las herramientas de desarrollo mostró que al inspeccionar el objeto de respuesta de autenticación se incluyen campos como `auth_token`, `email`, `userId`, e incluso metainformación de roles. Esta información permanece visible en consola y puede ser interceptada.

Impacto

La exposición de datos internos facilita la enumeración de usuarios, el secuestro de sesiones, y la comprensión de la lógica de autorización del sistema. Además, debilita la defensa en profundidad al entregar detalles de implementación que no deberían ser públicos.

Recomendación

Limitar estrictamente los campos devueltos por el backend a aquellos necesarios para el funcionamiento funcional del frontend. Separar el contexto público del contexto privado. Evitar que tokens o identificadores críticos sean manipulables o visibles en el cliente.

Herramientas empleadas

- **Burp Suite:** Proxy de interceptación para análisis y manipulación de solicitudes. Se utilizó su módulo Repeater para modificar parámetros y observar comportamientos del servidor ante entradas maliciosas.
- **OWASP ZAP:** Escáner de vulnerabilidades automatizado para análisis estático y dinámico. Detectó con éxito los vectores XSS, rutas expuestas y cabeceras inseguras.
- **Google Chrome Developer Tools:** Exploración del DOM, tráfico de red, y análisis de JavaScript inyectado desde el cliente. Permite validar los resultados observados desde el servidor.

Conclusión

La aplicación analizada presenta múltiples vectores de ataque críticos que, si no se corrigen, podrían comprometer gravemente la confidencialidad y la integridad del sistema. Las vulnerabilidades encontradas son el resultado de una ausencia de validaciones robustas, mecanismos inadecuados de codificación de salidas, y una arquitectura que expone en exceso la lógica interna al cliente. Las recomendaciones presentadas no solo abordan las fallas individuales, sino que constituyen una base de buenas prácticas para una arquitectura web segura y resiliente. Se recomienda complementar este análisis con pruebas adicionales sobre control de acceso, gestión de sesiones, y configuración segura del servidor.